NOTES · PART 5

SECURITY, NUMBERS AND LINK UPDATES

Memorandum on Agentic AI Applications · 24 Oct 2026 · continues Part 4

Contents

XVII. Inside the security rules

XVIII. Numbers worth remembering

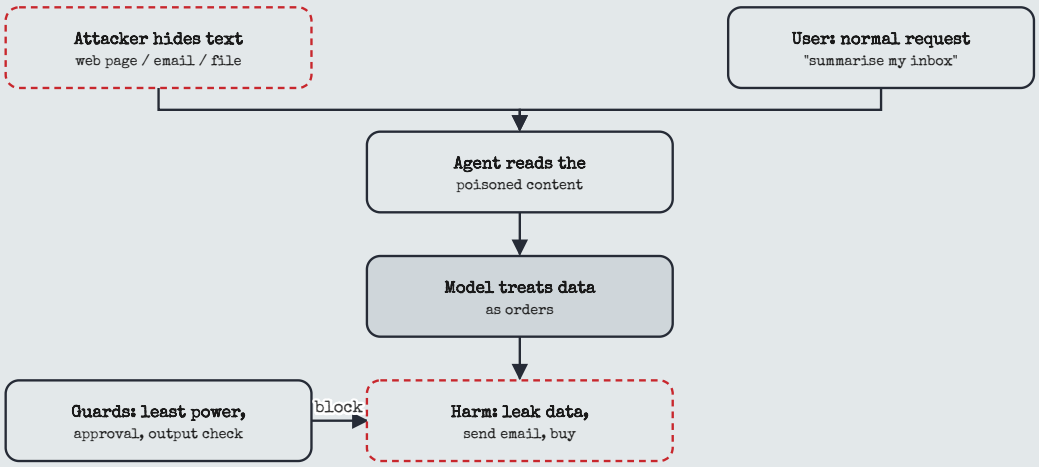
XIX. Link updates for Part 1

XX. In one line

Diagram key: a shaded box is the AI model or agent, a red dashed box is a risk or a guard, plain boxes are people, tools, data and results. A dashed arrow means "go back and repeat".

XVII. INSIDE THE SECURITY RULES

1. How indirect prompt injection works



The attack arrives through data the agent reads, not from the user.

- Hidden text can be white-on-white, in HTML comments, or fetched in a second step. One poisoned web page turned Bing Chat into a scammer against its own user.
- There is no complete fix yet. Limit what the agent is allowed to do, ask a human before risky actions, and never let the agent choose whose data it reads (Part 1, rule 2).

2. The OWASP list mapped to your app

RISK (LLM TOP 10, 2025)	WHERE IT HITS	PART 1 RULE THAT HELPS
01 Prompt injection	anything the agent reads	2, 5
02 Sensitive info leaks	answers and logs	2
03 Supply chain	models, packages, plugins	3
04 Data and model poisoning	documents in your RAG	3
05 Unchecked output	output passed to code or HTML	check before use
06 Too much agency	tools that act	5
07 System prompt leaks	instructions	1 (keep secrets out of prompts)
08 Vector store weaknesses	RAG index	2
09 Misinformation	answers	RAG checks (XI)
10 Unbounded use (cost)	loops, big inputs	turn limits, spend caps

- For phone apps, the Mobile Top 10 (2024) starts with improper credential use: the reason Part 1 says keys never ship in the app.
- Some news sites reported a 2026 edition of the LLM list in August 2026. The official page still showed 2025 on 24 Oct 2026, so check before quoting it.

> READ THE PAPER
>
> ▸ Indirect Prompt Injection (Greshake et al., 2023): the attack in detail
>
> ▸ OWASP Top 10 for LLM Applications 2025: the full list
>
> ▸ OWASP Mobile Top 10: phone app risks

XVIII. NUMBERS WORTH REMEMBERING

NUMBER	WHAT IT MEANS	FROM
+34 / +10 pts	ReAct over older trained methods on two decision tasks	ReAct
6.7B beats 175B	A small model with tools beat GPT-3 on maths and fact questions	Toolformer
21 million	Wikipedia pieces searched in the first RAG paper	RAG
100% vs under 40%	Shape-following with strict structured output vs an older model	Structured Outputs
90% better, 15× tokens	Lead + helpers vs one agent, and the cost	Anthropic research system
85.9%	MetaGPT on a standard coding test (2023)	MetaGPT
2,294 tasks / under 2%	SWE-bench size, and the best score at launch	SWE-bench
12.5% vs 3.8%	Better agent commands vs plain search	SWE-agent
680,000 hours	Audio used to train Whisper	Whisper
about 0.6 GB per 1B	Memory for a 4-bit local model	llama.cpp / Ollama

XIX. LINK UPDATES FOR PART 1

Some links in Part 1's reading list now redirect. They still work, but these are the current addresses:

PART 1 NO.	TITLE	CURRENT LINK
1	Building effective agents	https://www.anthropic.com/research/building-effective-agents
7	Tool use with Claude	https://platform.claude.com/docs/en/agents-and-tools/tool-use/overview
8	Streaming messages	https://platform.claude.com/docs/en/build-with-claude/streaming
11	Writing effective tools for agents	https://www.anthropic.com/research/writing-tools-for-agents
13	Multi-agent research system	https://www.anthropic.com/research/multi-agent-research-system
19	Human-in-the-loop (LangGraph)	https://docs.langchain.com/oss/python/langgraph/interrupts
24	Durable execution (LangGraph)	https://docs.langchain.com/oss/python/langgraph/durable-execution
25	Voice agents guide	https://developers.openai.com/api/docs/guides/voice-agents
new	Effective context engineering	https://www.anthropic.com/research/effective-context-engineering-for-ai-agents

For a full memo on each paper, see *Agentic AI Paper Memos.pdf*. For videos, see *Agentic AI YouTube videos.pdf*. Both are on the Desktop.

XX. IN ONE LINE

Inside every part is the same idea: let the model decide, but let code check. Tools return short, exact answers. Search results are graded. Output shapes are enforced. Risky steps wait for a human. Progress is saved after every step. Everything the agent reads is treated as data, never as orders.

* * *